SECURING AI AGENTS AND APPLICATIONS

A Comprehensive Technical White Paper

Covering Microsoft 365 Copilot · Copilot Studio · Power Platform · Microsoft Foundry
Microsoft Fabric · Azure AI · Security Platform · Agent 365 · Entra · Defender · Purview · Sentinel· Security Copilot

Version 1.0 | February 2026

Executive Summary

The proliferation of AI agents across enterprise environments has created a fundamentally new security challenge. Unlike traditional software, AI agents operate with natural language instructions, access multiple data sources simultaneously, execute actions with real-world consequences, orchestrate other agents, and interact with external systems through open protocols. The Microsoft platform has evolved rapidly to address these challenges establishing a new baseline for enterprise AI security posture.

This white paper provides a comprehensive technical reference for security architects, platform engineers, and governance professionals responsible for securing AI agents and applications across the Microsoft ecosystem. It covers:

- Agent observability, management and governance control plane for all agents using Agent 365
- Identity and access management for agents, humans, and agent-to-agent interactions using Microsoft Entra and the Entra Suite
- Threat protection across agent workloads using Microsoft Defender for Cloud, Defender XDR, and Microsoft Sentinel
- Data security, classification, and governance using the full Microsoft Purview suite including DSPM.
- Platform-native security controls within Microsoft 365 Copilot, Power Platform, Copilot Studio, Microsoft Foundry, Microsoft Fabric, and Azure
- Protocol-level security for MCP (Model Context Protocol) and A2A (Agent-to-Agent) communications
- DevSecOps integration including GitHub Advanced Security, AI Landing Zones, and threat modeling
- Security Copilot as the AI-powered security operations layer unifying the Microsoft Security platform

The framework presented here reflects the principle that AI agent security is not a single product capability but a defense-in-depth architecture spanning identity, network, data, application, and operational layers — with AI-powered security tooling amplifying human analyst capacity at every tier.

Table of Contents

1. The AI Agent Security Landscape
2. Microsoft AI Platform Architecture Overview
3. Microsoft 365 Copilot and Copilot Chat Security
4. Copilot Studio and Power Platform Agent Security
5. Microsoft Foundry — Building Secure AI Applications
6. Microsoft Fabric — Securing Data Agents
7. Identity and Access Management — Microsoft Entra as the Control Plane
8. Threat Protection — Microsoft Defender Platform
9. Security Operations — Microsoft Sentinel and Security Copilot
10. Data Security and Governance — Microsoft Purview
11. Agent Governance – Microsoft Agent 365
12. Protocol Security — MCP and Agent-to-Agent (A2A)
13. API Management and Security Considerations
14. DevSecOps — GitHub, CI/CD, and AI Landing Zones
15. Cross-Platform Security Comparison
16. Limitations, Gaps, and Roadmap Considerations
17. Implementation Roadmap
18. Summary and Conclusion

1. The AI Agent Security Landscape

1.1 What Makes AI Agents Different

Traditional application security models were designed around deterministic software: code that executes predictable paths, processes known inputs, and produces defined outputs. AI agents fundamentally break this model. They interpret natural language instructions, make autonomous decisions about tool use, maintain context across complex multi-step tasks, chain to other agents, and interact with external systems through dynamic API calls. This creates a qualitatively different threat surface.

Key security-relevant differences include:

- Prompt injection vulnerability: agents can be manipulated through malicious content embedded in retrieved data, tool outputs, or user messages, causing them to take unintended actions
- Indirect data access: agents retrieve information from knowledge bases, SharePoint, emails, and external APIs — creating data exfiltration paths that bypass traditional DLP controls
- Action execution scope: agents with broad tool permissions can send emails, create calendar events, modify files, call APIs, or execute code — each representing a potential blast radius
- Context persistence: long-running agents maintain conversation history and intermediate state, which can be exploited or leaked
- Model non-determinism: the same input can produce different outputs across invocations, making behavior auditing challenging
- Trust chain complexity: a user trusts an agent, the agent trusts its orchestrator, the orchestrator trusts sub-agents and tools — each trust relationship is an attack surface

1.2 The Expanded Attack Surface

The AI agent attack surface spans five dimensions:

Attack Vector	Description	Example Threat
Prompt Injection	Malicious instructions embedded in retrieved content redirect agent behavior	Web page returned by Bing contains hidden instructions to exfiltrate email data
Data Poisoning	Training or retrieval data is corrupted to influence agent outputs	SharePoint document modified to contain false financial data ingested by a Finance agent
Privilege Escalation	Agent acquires permissions beyond its intended scope	Low-privilege agent invokes high-privilege sub-agent without authorization check
Supply Chain Attack	Malicious MCP server, tool, or plugin compromises agent behavior	Third-party MCP server returns tool results that cause agent to exfiltrate data
Model Extraction	Systematic querying reveals sensitive training or system prompt content	Attacker reconstructs proprietary business logic from agent responses
Agent Impersonation	Malicious agent poses as a trusted agent in an A2A workflow	Fake orchestrator agent intercepts tasks intended for a trusted financial agent

1.3 Regulatory and Compliance Context

Organizations deploying AI agents face an evolving regulatory landscape. The EU AI Act classifies certain AI systems in high-risk categories requiring conformity assessments, technical documentation, and human oversight mechanisms. NIST AI RMF provides a framework for identifying, governing, mapping, measuring, and managing AI risk. SEC cybersecurity disclosure rules increasingly apply to AI-related incidents. Industry-specific regulations (HIPAA, PCI-DSS, SOX) impose data handling requirements that apply equally to AI-processed data.

Microsoft's platform approach embeds compliance controls at the platform level where possible, but organizations retain responsibility for configuring and validating those controls. This white paper addresses the technical controls that map to these regulatory requirements throughout.

NOTE — Regulatory Landscape Evolution

The regulatory environment for AI is evolving rapidly. Controls described here reflect the state as of early 2026. Organizations should monitor developments in the EU AI Act implementation, the forthcoming NIST AI RMF 2.0, and jurisdiction-specific requirements. Microsoft Purview's Compliance Manager includes AI-specific assessment templates that are updated regularly.

2. Microsoft AI Platform Architecture Overview

2.1 Platform Layers

Microsoft's AI agent platform spans five distinct layers, each with its own security model, administrative controls, and integration points with the Microsoft Security platform:

Layer	Primary Platforms	Target Persona	Security Governance Model
End-User AI Experience	M365 Copilot, Copilot Chat, Microsoft 365 Apps	Knowledge workers, business users	Microsoft 365 security + Purview + Entra
Low-Code Agent Building	Copilot Studio, Power Platform, Agent Builder	Citizen developers, business analysts	Power Platform DLP, Copilot Studio governance, Purview
Professional AI Development	Microsoft Foundry (formerly Azure AI Foundry)	AI engineers, data scientists	Azure RBAC, Defender for Cloud, Purview, Entra
Data & Analytics AI	Microsoft Fabric, Data Agents	Data engineers, analysts	Fabric security, Purview, Entra, OneLake governance
Infrastructure & Platform	Azure OpenAI, Azure AI Services, AKS, API Management	Platform teams, SREs	Azure Policy, Defender for Cloud, Sentinel, Entra

2.2 The Microsoft Security Platform — Unified Architecture

Microsoft's security platform has converged around a unified architecture that spans all AI layers. The key components and their relationships are:

Microsoft Entra — Identity Control Plane

Entra serves as the identity foundation for all Microsoft AI platforms. Workload identities for agents, managed identities for Azure resources, human identities for developers and users, and external identities for partner integrations all flow through Entra. The Entra Suite adds Verified ID, Entra Internet Access, Entra Private Access, and Entra ID Governance to extend identity controls across the full agent lifecycle.

Microsoft Defender — Threat Protection Layer

The Defender family has expanded significantly to cover AI workloads: Defender for Cloud now includes AI workload protection for Azure OpenAI and Foundry deployments; Defender XDR has added AI-specific detections; Defender for Endpoint protects agent host infrastructure; and the new AI Security Posture Management (AI-SPM) capability provides continuous visibility into AI-specific risks across the estate.

Microsoft Purview — Data Governance Layer

Purview provides the data security and compliance layer across all AI platforms. DSPM provides specific controls for AI-related data risks including sensitive data exposure in prompts, oversharing through AI

tools, and compliance violations. Purview's Information Protection labels flow from documents into AI retrieval pipelines, ensuring classification-aware access even within agent knowledge bases.

Microsoft Sentinel — Security Operations Layer

Sentinel has evolved into the central security operations hub for AI workloads. The Sentinel Data Lake architecture (announced Ignite 2025) enables cost-effective retention of high-volume AI interaction logs. The Microsoft Graph MCP Server (available from the Sentinel team) enables Security Copilot to query Sentinel data through natural language. Together these form the foundation of AI-aware security operations.

Security Copilot — AI-Powered Security Operations

Security Copilot is now deeply integrated across Defender, Sentinel, Purview, and Entra, providing AI-powered investigation, triage, and response capabilities. Crucially, Security Copilot is now available as an embedded experience within Defender XDR, Sentinel, and Purview rather than only as a standalone portal. The Security Copilot agent platform allows organizations to build custom security agents using the same Microsoft Foundry infrastructure.

3. Microsoft 365 Copilot and Copilot Chat Security

3.1 Architecture and Data Access Model

Microsoft 365 Copilot operates within the Microsoft 365 trust boundary. It accesses data through the Microsoft Graph on behalf of the authenticated user, meaning it is constrained to data the user already has permission to access. This is a critical architectural distinction: Copilot does not elevate permissions, it inherits them.

However, this creates the "oversharing problem" — if users have been granted excessively broad access to SharePoint, Teams channels, or emails, Copilot can retrieve and surface that data in response to natural language queries in ways that traditional access patterns would not have exposed.

3.2 Data Access Governance Controls

SharePoint Advanced Management (SAM)

SharePoint Advanced Management, available as an add-on to Microsoft 365, provides the primary controls for managing SharePoint oversharing risks that directly impact Copilot:

- Site Access Review: automated identification and review of broadly shared sites, with workflow for remediating oversharing before Copilot deployment
- Restricted SharePoint Search (RSS): limit Copilot to searching only SharePoint sites explicitly added to an allow-list, preventing broad organizational data access during initial rollout
- Data Access Governance (DAG) reports: identify sites with Anyone links, broad organization-wide permissions, or sensitivity labels that conflict with their sharing settings
- Site ownership and activity reports: identify abandoned or orphaned sites with sensitive content that should be governed before Copilot deployment
- Conditional Access policies for SharePoint: apply device compliance, location, and authentication requirements to SharePoint access that flow through Copilot
- Tenant-wide and site-level sharing restriction policies: programmatically enforce sharing boundaries that constrain Copilot retrieval scope

RECOMMENDED ACTION — Pre-Copilot SharePoint Hygiene

Organizations should run the SharePoint Advanced Management DAG reports and complete a site access review before enabling Microsoft 365 Copilot. Enabling Restricted SharePoint Search as an initial control allows a phased expansion of Copilot's knowledge base as governance confidence increases. Purview DSPM for AI can supplement this by identifying sensitive data at rest before Copilot deployment.

Microsoft Purview Integration

Microsoft Purview is deeply integrated with M365 Copilot at multiple layers:

- Sensitivity label enforcement: Copilot respects sensitivity labels on documents — if a document is labeled Highly Confidential with a protection template that restricts access to specific groups, Copilot will not surface that content to users outside those groups
- Copilot interaction data in Purview: all Copilot prompts and responses are available in Purview eDiscovery and Audit Log, treating AI interactions as first-class data governance objects

- Copilot DLP policies: Purview DLP policies can be applied to Copilot interactions, blocking responses that contain specific sensitive information types from being rendered to the user
- Communication Compliance for Copilot: policies can analyze Copilot prompts and responses for policy violations, inappropriate content, or regulatory compliance issues
- DSPM for AI: continuously monitors Copilot activity for data risks including sensitive data surfaced in responses, unusual access patterns, and policy violations

3.3 Microsoft 365 Copilot Administrative Controls

Copilot Administration Center

The M365 Admin Center and Copilot-specific management pages provide:

- Per-user and per-group Copilot license assignment enabling controlled rollout
- Plugin management: control which Copilot plugins (Graph connectors, first-party and third-party extensibility) are available to which users
- Copilot for Teams meeting summaries: controls for meeting recording consent, transcript availability, and AI-generated summaries
- Web search integration controls: enable or disable Copilot's ability to search the public web, which affects both capability and data exfiltration risk

Copilot Chat (Previously Bing Chat Enterprise) Controls

Copilot Chat operates as an enterprise-grade AI assistant with commercial data protection. Key security controls:

- Enterprise data protection: Copilot Chat prompts and responses are not used to train Microsoft models and are not retained beyond the session
- Entra-based authentication: requires Entra ID authentication, ensuring only licensed users in the tenant can access the experience
- Purview DLP integration: DLP policies apply to Copilot Chat interactions for paste-in content scenarios
- Microsoft Defender for Cloud App Security integration: Copilot Chat activity is visible in MCAS for behavioral analytics and anomaly detection

3.4 Agent Builder and Declarative Agents in M365

Microsoft 365 Copilot extensibility through declarative agents (built in Agent Builder or Copilot Studio and deployed to M365) creates additional governance requirements:

- Declarative agents operate within the same permission boundary as the user — they cannot escalate beyond what the user has access to
- Agent manifest review: declarative agent manifests that specify system prompts, knowledge sources, and capabilities should be reviewed for security implications before organizational deployment
- Integrated apps approval workflow: declarative agents deployed as integrated M365 apps require admin approval through the M365 Admin Center before organization-wide availability
- Sensitivity label inheritance: when declarative agents create documents or responses, sensitivity label inheritance policies apply based on the content type and knowledge source labels
- Copilot Studio governance policies (see Section 5) apply when agents are built in Copilot Studio and deployed to M365 Copilot

4. Copilot Studio and Power Platform Agent Security

4.1 Copilot Studio Security Architecture

Copilot Studio is Microsoft's low-code platform for building AI agents. Agents built in Copilot Studio can be deployed to Teams, web channels, M365 Copilot, or custom applications. The security architecture spans three layers:

Platform Layer — Power Platform Governance

Copilot Studio is built on Power Platform, so Power Platform governance controls are the foundational layer:

- Power Platform environments: agents are deployed to specific environments (Development, Test, Production) providing isolation between lifecycle stages. Environment-level security policies apply to all agents within.
- Data Loss Prevention (DLP) Policies: Power Platform DLP policies classify connectors into Business, Non-Business, and Blocked tiers. Agents cannot use connectors that are blocked or mix Business and Non-Business tier connectors in a single agent, preventing data from flowing between incompatible data sources.
- Environment Admin Center governance: administrators can restrict who can create environments, who can create agents, and which connectors are available through tenant-level policies
- Power Platform Center of Excellence (CoE) Starter Kit: provides governance dashboards, compliance reporting, and automated remediation for Power Platform and Copilot Studio deployments at scale

Agent Layer — Copilot Studio Native Controls

Copilot Studio provides agent-specific security controls:

- Agent authentication: agents can be configured as No Authentication (anonymous), Microsoft (Entra-based), or Custom (third-party IdP). Enterprise deployments should use Microsoft authentication to enforce Entra-based access controls.
- Knowledge source permissions: Copilot Studio respects SharePoint permissions when indexing SharePoint knowledge sources — agents only surface content the querying user can access
- Generative AI content safety: built-in content filtering for Copilot Studio agents (powered by Azure AI Content Safety) blocks harmful outputs across hate speech, violence, sexual content, and self-harm categories
- Agent Flows security: when agents trigger Power Automate flows, the flow runs under a specific connection identity that should be a dedicated service account with least-privilege access
- Topic and action review: the Copilot Studio authoring experience provides a review of all agent topics and actions, enabling security review before publishing

AI Prompt Security Controls in Copilot Studio

Copilot Studio has added specific controls for prompt security as of late 2025:

- System prompt protection: the system prompt (instructions) for an agent can be marked as non-extractable, preventing the agent from revealing its own instructions to users
- Prompt injection detection: built-in detection for common prompt injection patterns with configurable alerting

- Jailbreak resistance: hardening against attempts to override the agent's configured behavior through user messages

4.2 Power Platform DLP Architecture for AI Agents

Designing effective DLP policies for Copilot Studio and Power Platform agents requires understanding the connector classification model:

Connector Tier	Examples	Security Implication
Business	SharePoint, Teams, Dataverse, M365 connectors	Approved for enterprise data — can co-exist with other Business tier connectors
Non-Business	Consumer social platforms, personal storage	Cannot mix with Business tier — prevents enterprise data flowing to consumer services
Blocked	Specific connectors prohibited by policy	Cannot be used in any agent or flow within the policy scope
Custom Connectors	Organization-built or third-party APIs	Require explicit classification — unclassified customs default to Non-Business

Key DLP policy design recommendations for AI agents:

- Create environment-level DLP policies that are more restrictive than tenant-level policies for development environments
- Block all HTTP/custom connector endpoints not explicitly approved for production agent environments
- Use endpoint filtering for SharePoint and OneDrive connectors to restrict agents to approved tenant domains only
- Audit DLP policy violations — every violation represents a potential data flow that security teams should investigate
- Review DLP policies whenever new AI connectors are released — Microsoft regularly releases new Copilot Studio connectors that require classification

4.3 Managed Environments and Agent Governance

Power Platform Managed Environments (a premium feature) provide additional governance capabilities critical for production AI agents:

- Solution checker enforcement: automatic APEX and rule-based quality checks before solution deployment, preventing agents with known security anti-patterns from reaching production
- Pipelines for Power Platform: built-in ALM (Application Lifecycle Management) pipelines with approval gates between Development, Test, and Production environments
- Sharing limitations: restrict agents from being shared outside the environment or organization
- IP firewall for Dataverse: restrict Dataverse access (the primary data store for Power Platform agents) to approved IP ranges, preventing exfiltration to unauthorized networks
- Customer-managed keys: encrypt Dataverse data at rest with organization-controlled keys through Azure Key Vault

4.4 Copilot Studio and Purview Integration

Copilot Studio integrates with Microsoft Purview for:

- Sensitivity label awareness in knowledge retrieval: agents built in Copilot Studio respect sensitivity label-based access restrictions on SharePoint content
- Audit logs in Purview: agent interactions, configuration changes, and publishing events are captured in Purview Audit Logs
- Communication Compliance policies: agent-to-user conversations can be subject to Communication Compliance review policies for regulated industries
- Data retention policies: Copilot Studio conversation history can be subject to Purview retention and deletion policies

GAP — Advanced Purview Integration

Full sensitivity label inheritance from source documents to AI-generated agent responses in Copilot Studio is on the roadmap but not yet generally available for all channels. Organizations with strict label inheritance requirements should evaluate this gap carefully and implement compensating controls such as Communication Compliance policies.

5. Microsoft Foundry — Building Secure AI Applications

5.1 Microsoft Foundry Overview

Microsoft Foundry (the rebranded and expanded Azure AI Studio / AI Foundry platform) is the professional-grade platform for building, deploying, and managing AI applications and agents. Foundry has consolidated Azure OpenAI Service, Azure AI Services, model catalog, evaluation tooling, and agent tooling into a unified platform with a substantially enhanced security posture.

5.2 Foundry Project Security Architecture

Hub and Project Model

Foundry organizes resources into Hubs (central governance objects with shared infrastructure) and Projects (workspaces for specific AI applications). This hierarchy maps naturally to security governance:

- Hub level: shared Azure Key Vault, shared Azure Storage, managed network configuration, shared monitoring workspace. Hub administrators control what resources are available to all projects.
- Project level: project-specific model deployments, fine-tuning experiments, evaluations, and agent definitions. Project-level RBAC controls who can modify agents within a project.

Network Security for Foundry

Foundry supports multiple network isolation configurations:

- Allow Internet Outbound (development mode): outbound internet access permitted — not recommended for production
- Allow Only Approved Outbound: managed virtual network with outbound rules restricting to approved endpoints (Azure services, specific FQDNs)
- Disabled (fully private): all traffic over private endpoints, no internet connectivity from the managed network — recommended for sensitive production workloads

Private endpoint configuration for Foundry includes:

- Azure AI Foundry private endpoint in the customer VNet for inbound access from internal consumers
- Managed private endpoints from Foundry's managed VNet to Azure Storage, Azure Key Vault, Azure AI Services, and Azure OpenAI resources
- Private DNS zones properly configured to resolve Foundry endpoints within the private network
- NSG (Network Security Group) rules on the customer VNet subnet restricting inbound access to Foundry to approved source ranges

Identity and RBAC for Foundry

Foundry uses Azure RBAC with the following key roles:

Role	Scope	Permissions	Recommended Assignment
Azure AI Developer	Project	Create/manage projects, deployments, agents, evaluations	AI engineers, data scientists

Role	Scope	Permissions	Recommended Assignment
Azure AI Inference Deployment Operator	Project	Deploy models to existing endpoints, read-only to models	DevOps engineers, platform teams
Cognitive Services OpenAI User	Azure OpenAI resource	Submit inference requests, read models	Application service principals, agents
Cognitive Services OpenAI Contributor	Azure OpenAI resource	Create deployments, fine-tune, manage models	AI engineers with fine-tuning responsibility
Azure AI Hub Owner	Hub	Full control of hub including shared resources	Hub administrators — use PIM

Content Safety and Model Evaluation

Azure AI Content Safety is a critical security control for Foundry-based agents:

- Prompt Shield: detects prompt injection attacks and jailbreak attempts in both user messages and retrieved document content before they reach the model. Available as an API and as a built-in Foundry evaluation.
- Groundedness detection: identifies responses that are not grounded in the provided context, catching hallucinations and potential prompt injection outputs
- Protected material detection: identifies responses that reproduce copyrighted content or training data memorization
- Custom blocklists: organization-specific terms, competitor names, or sensitive project codenames that should not appear in agent responses
- Multi-category content filtering: configurable thresholds for hate speech, violence, sexual content, and self-harm across both input and output

Azure AI Content Safety as a Security Control Layer

Foundry provides the Azure AI Content Safety integration at the platform level, allowing a single safety configuration to apply across all models deployed in a Hub. This centralization is a significant governance improvement over per-application content filtering.

RECOMMENDED CONFIGURATION

For production Foundry deployments, enable Prompt Shield for both User Prompt and Document injection modes. Configure custom blocklists with organization-sensitive terms. Set content filtering to Strict for high-risk consumer-facing agents and Moderate for internal enterprise agents. Log all content filter decisions to a Log Analytics workspace connected to Sentinel.

5.3 Azure AI Landing Zone Architecture

The Azure AI Landing Zone (now documented as part of the Azure Landing Zone accelerator) provides a reference architecture for deploying AI workloads in a governed, scalable manner:

Core Landing Zone Components

- Management Group hierarchy: AI workloads deployed under a dedicated AI Management Group with Azure Policy initiatives enforcing network isolation, encryption, and monitoring requirements
- Hub-and-spoke network topology: AI workloads in spoke VNets connected to a shared hub containing Azure Firewall, Private DNS Zones, and VPN/ExpressRoute gateways

- Policy-as-code: Azure Policy initiatives enforcing Foundry private endpoint requirements, Azure OpenAI deployment restrictions, encryption with customer-managed keys, and diagnostic settings
- Shared monitoring: centralized Log Analytics workspace receiving diagnostic logs from all AI resources, feeding into Sentinel
- Key Vault per environment: dedicated Azure Key Vault instances per environment (dev/test/prod) with RBAC-based access and purge protection enabled

Azure Policy for AI Governance

Key Azure Policy definitions for AI workloads (many available in built-in policy initiatives):

- Require private endpoints for Azure AI Foundry hubs and projects
- Restrict Azure OpenAI deployment to approved model families and versions
- Require customer-managed key encryption for Azure AI Storage accounts
- Deny public network access on Azure OpenAI resources
- Require diagnostic settings to Log Analytics workspace for all AI cognitive services
- Restrict Foundry outbound traffic to approved configurations (deny Allow Internet Outbound in production)
- Enforce Defender for Cloud Enhanced Security for AI workloads on all subscriptions

5.4 Foundry Agent Framework Security

The Foundry Agent Framework (formerly the Azure AI Agent SDK) provides a structured way to build multi-step, tool-using agents. Security considerations specific to the framework include:

Tool and Function Calling Security

- Input validation: all tool inputs received from the LLM should be validated against expected schemas before execution — the LLM output is untrusted input from a security perspective
- Sandboxed code execution: when using Code Interpreter (the built-in code execution sandbox), Foundry provides an isolated execution environment. For custom code execution tools, use Azure Container Apps or ACI with minimal permissions.
- Tool permission scoping: each tool registered with an agent should operate under a dedicated managed identity or service principal with only the permissions needed for that tool
- Tool output filtering: tool outputs should be filtered before being returned to the agent to prevent injection of malicious instructions through tool results (e.g., a web search tool should sanitize returned HTML)

Agent Storage Security

Foundry agents maintain conversation threads and file attachments in Azure Storage:

- Encrypt agent thread storage with customer-managed keys through Azure Key Vault
- Apply data retention policies to agent thread storage aligned with organizational records retention requirements
- Restrict access to agent thread storage to the specific agent service principal and authorized administrators
- Enable soft delete and versioning on agent storage accounts to support forensic investigation of agent interactions

6. Microsoft Fabric — Securing Data Agents

6.1 Microsoft Fabric Security Architecture

Microsoft Fabric is Microsoft's unified analytics platform combining data engineering, data science, real-time analytics, and business intelligence in a single SaaS experience. Data agents in Fabric — AI-powered interfaces that allow natural language queries against Fabric data — introduce specific security considerations on top of Fabric's underlying security model.

6.2 Fabric Security Foundation

OneLake Security

OneLake is the foundational data lake underlying all Fabric workloads. Security controls for OneLake:

- Entra ID-based authentication for all OneLake access — no anonymous access
- OneLake Data Access Roles: role-based access control at the folder and file level within a Fabric lakehouse, enabling fine-grained data access scoping for agents
- Private Links for Fabric: restrict OneLake access to approved private network connections, preventing internet-based access to organizational data
- Azure Private Link for Fabric capacity: isolate the Fabric compute capacity within a private network boundary
- Managed Private Endpoints from Fabric to external data sources: allow Fabric to connect to Azure SQL, Azure Storage, and other resources without exposing them to the public internet

Workspace and Item Security

Fabric organizes data into Workspaces with role-based access:

- Workspace roles (Admin, Member, Contributor, Viewer) control what users can do within a workspace — AI agents should be assigned the minimum workspace role needed, typically Viewer or a custom role
- Item-level permissions allow sharing specific lakehouses, warehouses, or semantic models without granting full workspace access
- Row-Level Security (RLS) in semantic models: data agents querying through a semantic model will inherit RLS policies, limiting query results to data the querying identity is authorized to see
- Column-Level Security (CLS) in warehouses: restrict access to specific columns containing PII or sensitive fields, preventing agents from accessing columns they have no business need for
- Object-Level Security (OLS) in semantic models: control which tables and columns are visible to specific Entra security groups that agents are members of

6.3 Data Agent Security

Fabric Data Agents (GA as of late 2025 for selected regions) provide natural language interfaces over Fabric data. Security controls specific to data agents:

- Agent identity: Fabric data agents run under a service principal with access to the specific Fabric items configured for the agent — not tenant-wide access

- Permitted data sources: administrators explicitly configure which lakehouses, warehouses, and semantic models a data agent can query — the agent cannot independently discover or access other Fabric items
- Query boundary enforcement: data agents generate SQL/DAX queries that are executed against Fabric through the normal Fabric security stack, meaning all Fabric security controls (RLS, CLS, OLS) apply to agent queries
- System prompt isolation: the agent's system prompt, which configures its behavior and data source descriptions, is protected from user extraction
- Audit logging: all data agent queries and responses are logged to Fabric monitoring, which feeds into Purview Audit and Sentinel

6.4 Purview Integration for Fabric

Microsoft Purview provides governance across Fabric through deep native integration:

- Purview Data Map scanning: Purview automatically scans Fabric lakehouses and warehouses, discovering and classifying sensitive data using built-in and custom classifiers
- Sensitivity label propagation: sensitivity labels applied to Power BI reports flow to Fabric semantic models; labels on lakehouse tables flow to downstream artifacts
- Data lineage: Purview tracks data lineage across Fabric — understanding how data flows from source to lakehouse to semantic model to data agent response is critical for data governance
- Access Policy through Purview: Purview Data Use Governance policies can enforce that specific Fabric data can only be accessed by approved users for approved purposes, with approval workflow
- DSPM for AI in Fabric: DSPM for AI monitors data agent interactions for sensitive data exposure, unusual query patterns, and policy violations

6.5 Real-Time Intelligence Security

Fabric Real-Time Intelligence (RTI) — enabling agents to query streaming data — adds specific security considerations:

- KQL Database security: role-based access for KQL databases hosting real-time data, with Table-Level Security and Column-Level Security capabilities
- Event stream source authentication: connections from event streams (Event Hubs, IoT Hub, Kafka) require proper authentication and should use managed identities
- Real-time data in agents: agents querying streaming data can access time-sensitive information; access control changes should propagate quickly to avoid stale permission states

7. Identity and Access Management — Microsoft Entra as the Control Plane

7.1 Entra Identity Hierarchy for AI Workloads

A comprehensive identity architecture for AI agents must address three distinct identity classes:

Human Identities

Users interacting with AI agents, developers building them, and administrators governing them all require carefully scoped human identities managed through Entra ID. Key controls include:

- Conditional Access policies enforcing MFA, compliant device requirements, and location-based restrictions for access to AI tools
- Privileged Identity Management (PIM) for just-in-time elevation of administrative access to Copilot Studio, Foundry, and Fabric environments
- Entra ID Governance lifecycle automation ensuring access to AI tools is provisioned and deprovisioned with employment changes
- Authentication Strength policies requiring phishing-resistant credentials (FIDO2 passkeys, Windows Hello for Business) for access to high-sensitivity AI environments

Workload Identities — Agent Identities

AI agents themselves are principals that require identity and access management. Microsoft has significantly expanded workload identity capabilities for AI:

- Managed Identities for Azure-hosted agents eliminate credential management by providing a platform-managed identity that can access Azure resources without secrets
- Workload Identity Federation enables GitHub Actions and other CI/CD systems to authenticate as Entra workload identities without long-lived secrets
- Conditional Access for Workload Identities (now generally available) allows location, IP range, and other condition-based policies to apply to agent service principals
- Entra Agent ID: a dedicated identity type for AI agents that provides agent-specific properties including declared capabilities, authorized data scopes, and trust level — enabling agents to have Entra identities distinct from application service principals

> **NOTE — Entra Agent ID Roadmap**
> Entra Agent ID was announced at Ignite 2025 as a preview capability. Full general availability with complete policy integration across Defender, Purview, and Sentinel is expected throughout 2026. Early adopters should plan for the identity model to evolve. Monitor Microsoft Entra release notes for updates.

Non-Human Identities (NHI)

Beyond AI-specific agents, enterprise environments contain large numbers of non-human identities including service accounts, API keys, OAuth applications, and automation principals. The Entra NHI governance capabilities provide:

- Discovery of all NHIs across the Entra tenant including applications, service principals, and managed identities
- Risk scoring for NHIs based on privilege level, age, unused status, and credential hygiene
- Automated lifecycle management including rotation prompts, orphaned credential detection, and deprovisioning workflows
- Integration with Defender for Cloud App Security for OAuth application discovery and anomaly detection

7.2 Entra Suite Components for AI Security

Microsoft Entra Internet Access

Entra Internet Access (the SSE component of the Global Secure Access platform) provides identity-aware, context-sensitive internet access controls that are particularly relevant for AI agents:

- Universal Conditional Access for internet destinations: apply MFA, compliant device, and other Entra Conditional Access conditions to internet-bound agent traffic
- Enriched network logs: internet-bound traffic from agents is logged with user and application context, enabling Sentinel to correlate agent network behavior with identity events
- FQDN and URL category-based filtering: restrict which external endpoints AI agents can reach at the network layer, complementing API management controls
- Token protection: prevent lateral movement using stolen tokens by binding tokens to the network session

Microsoft Entra Private Access

For AI agents that need to access on-premises resources or private cloud resources:

- Zero Trust Network Access (ZTNA) replacing traditional VPN for agent-to-private-resource connectivity
- Per-application access policies ensuring agents only reach the specific private resources they need
- Full audit trail of private resource access by agents through Entra sign-in logs

Microsoft Entra – AI Gateway

<< Insert section here on AI Gateway >>>>>

Microsoft Entra Verified ID

For multi-organizational AI deployments and partner scenarios:

- Verifiable credentials enabling cross-organization trust for agent-to-agent interactions where agents present verifiable claims about their identity and authorization
- Decentralized identity model supporting scenarios where agents from different tenants need to interact without sharing full Entra directory access

Entra ID Governance for AI Lifecycle

The Entra ID Governance suite addresses the full lifecycle of AI-related access:

- Access Reviews: scheduled reviews of which users have access to which Copilot, Foundry, or Fabric environments, with automated deprovisioning for unused access
- Entitlement Management: access packages bundling AI tool access with required training completion attestations and business justification
- Lifecycle Workflows: automated provisioning and deprovisioning of AI tool access tied to HR events (joiners, movers, leavers)
- Segregation of Duties: policies preventing users from holding conflicting AI-related roles (e.g., agent developer and production approver)

<Insert section on Agent Lifecycle management>>>

7.3 Conditional Access Architecture for AI Environments

A layered Conditional Access architecture for AI environments should include:

Policy Layer	Condition	Control	Applies To
Baseline Protection	All AI tool access	Require MFA + registered device	All users, all AI tools
Elevated Risk Response	Sign-in risk ≥ Medium (Entra ID Protection)	Require MFA step-up + compliant device	All users accessing AI tools
Sensitive AI Environments	Access to Foundry, Fabric, or production agents	Require phishing-resistant MFA + Intune compliant device + named location	Developers, admins, data engineers
Privileged AI Administration	Global Admin, Copilot admin roles	Require FIDO2 + PIM justification + limited session lifetime	Administrators
Agent Workload Identities	Service principals running agents	Restrict to approved IP ranges + require IP match for token use	AI agent service principals
Developer/DevOps Access	GitHub Actions, Azure DevOps	Workload Identity Federation — no long-lived secrets	CI/CD pipelines

7.4 Just-Enough Access for AI Agents

Applying least-privilege principles to AI agents requires decomposing the permissions an agent needs and ensuring it cannot exceed that scope even if compromised or manipulated through prompt injection:

- Microsoft Graph API scopes: grant agents only the Graph API permissions they explicitly need (e.g., Mail.Read for a mail-summarization agent, not Mail.ReadWrite)
- SharePoint site-level permissions: scope Copilot and agent SharePoint access to specific sites or libraries rather than tenant-wide

- Power Platform connector permissions: use custom connectors with explicit scope rather than broad service account credentials
- Azure RBAC scoping: assign agents Reader or specific data-plane roles scoped to specific resource groups rather than subscription-level Contributor
- Time-limited tokens: use short-lived access tokens (15-minute lifetime recommended for agent workloads) and refresh through managed identity flows
- Entra Conditional Access token binding: require token binding for high-sensitivity agent actions to prevent token theft and replay

8. Threat Protection — Microsoft Defender Platform

8.1 Defender for Cloud — AI Workload Protection

Microsoft Defender for Cloud has significantly expanded its AI workload security capabilities through the AI Security Posture Management (AI-SPM) plan and dedicated threat detections for Azure AI and Foundry.

AI Security Posture Management (AI-SPM)

AI-SPM provides continuous visibility into AI-specific security risks:

- AI attack surface mapping: discovers all AI resources across Azure subscriptions including Azure OpenAI deployments, Foundry hubs, AI Services resources, and AI-connected storage accounts
- AI-specific security recommendations: prioritized recommendations for AI resources covering network isolation, authentication configuration, content safety enablement, and diagnostic settings
- AI data sensitivity insights: integrates with Purview to identify AI resources with access to sensitive data, highlighting high-risk combinations (e.g., an Azure OpenAI deployment with access to a storage account containing PII)
- Model inventory and risk scoring: tracks deployed AI models with associated risk factors including model type, fine-tuning history, and data access scope

Defender for Cloud Threat Detections for AI

Defender for Cloud's AI-specific threat detections (GA as of late 2025) include:

- Anomalous Azure OpenAI API call patterns: detects unusual spikes in API calls, calls from unexpected geographic locations, or calls during unusual hours for a given deployment
- Azure OpenAI jailbreak detection: monitors completions for patterns indicating successful jailbreak attempts have bypassed content safety controls
- Sensitive data exposure in AI outputs: alerts when AI model outputs contain data patterns matching sensitive information types (SSNs, credit card numbers, credentials)
- Credential harvesting through AI: detects when AI queries appear designed to extract credentials or authentication material from documents in the knowledge base
- Anomalous model access from Compute: flags when compute resources (VMs, containers) access AI models in patterns inconsistent with their normal behavior

8.2 Microsoft Defender XDR — AI-Aware Detection and Response

AI-Specific Detection Rules

Defender XDR now includes detections spanning the AI attack surface:

- Copilot activity anomalies: Microsoft 365 Copilot interaction patterns are analyzed by Defender XDR, detecting unusual data access through Copilot (e.g., accessing unusually large volumes of data across many sites in a short time)
- Power Platform / Copilot Studio abuse: detections for agents configured to exfiltrate data through connectors, unusual connector usage patterns, and bulk data operations through Power Automate

- Insider threat in AI tools: correlates unusual AI tool usage with other behavioral indicators from Defender for Endpoint, Entra ID Protection, and Purview Insider Risk Management

Automated Investigation and Response (AIR) for AI Incidents

- Playbooks for AI incidents: pre-built investigation playbooks for common AI security incidents (Copilot data exfiltration suspicion, agent compromise, prompt injection detection)
- Automated containment: for confirmed AI-related threats, automated actions including disabling compromised Copilot plugins, blocking suspicious service principal activity, and isolating affected agents
- User risk escalation: elevated risk in Entra ID Protection triggered by AI-related anomalies can automatically increase Conditional Access requirements for the affected user

8.3 Defender for Endpoint — Protecting Agent Infrastructure

AI agents running on virtual machines, containers, or developer workstations require endpoint protection:

- Defender for Endpoint covers Windows, macOS, Linux, and container workloads that host AI agent runtimes
- ASR (Attack Surface Reduction) rules: specific ASR rules prevent credential theft attacks targeting developer workstations where AI API keys may be stored
- Vulnerability management: continuously identifies unpatched software in AI runtime environments (Python packages, model serving frameworks, container base images)
- Threat and Vulnerability Management (TVM) integration with Defender for Cloud: provides a unified vulnerability view across the AI workload stack from OS through application layer

8.4 Microsoft Defender for Cloud Apps (MDCA) — Shadow AI Governance

MDCA provides governance of unsanctioned AI application usage — a growing concern as employees adopt shadow AI tools:

- Cloud app catalog with AI app tagging: the MDCA catalog includes ratings for hundreds of AI applications with security and compliance assessments
- Shadow AI discovery: analyze proxy/firewall logs or Entra Internet Access logs to identify AI services employees are using that are not officially sanctioned
- Access block for unsanctioned AI apps: work with Entra Internet Access to block access to AI services that have not been approved by the security team
- Session policies for sanctioned AI apps: for approved third-party AI apps, apply session policies monitoring what data users are pasting into these tools
- OAuth app governance: detect and manage OAuth applications with AI capabilities that have been granted broad permissions to Microsoft 365 data

8.5 Threat Modeling for AI Agents

AI agent threat modeling should extend the traditional STRIDE model with AI-specific threat categories. The recommended approach uses the MITRE ATLAS (Adversarial Threat Landscape for Artificial-Intelligence Systems) framework in conjunction with STRIDE:

ATLAS Tactic	STRIDE Mapping	Key AI-Specific Techniques	Defender Control
ML Attack Staging	Reconnaissance	Discover AI model endpoints, probe API structures, identify training data sources	Defender for APIs discovery; APIM access controls
ML Model Access	Information Disclosure	Extract model parameters, infer training data, extract system prompts	Content Safety; Azure OpenAI access controls
Adversarial ML	Tampering	Craft adversarial inputs, poisoning attacks, prompt injection	Prompt Shield; Content Safety; input validation
ML Model Evasion	Elevation of Privilege	Bypass safety filters, jailbreaking, instruction override	Content Safety; jailbreak detection in Defender for Cloud
Exfiltration via AI	Information Disclosure	Use AI as exfil channel for sensitive data through natural language	Purview DLP; Defender XDR anomaly detection
Impact via AI	Denial of Service / Damage	Generate harmful content, cause agent to take destructive actions	Content Safety; human approval for sensitive actions

9. Security Operations — Microsoft Sentinel and Security Copilot

9.1 Microsoft Sentinel for AI Security Operations

Sentinel Data Lake Architecture

The Sentinel Data Lake fundamentally changes the economics and architecture of security data management. Key capabilities relevant to AI security operations:

- Tiered data storage: hot (Basic/Analytics tiers), warm (Auxiliary tier at lower cost), and archive tiers allow organizations to retain high-volume AI interaction logs economically
- Summary rules: automated aggregation of high-volume AI telemetry (e.g., hourly Azure OpenAI API call summaries) reduces storage cost while preserving analytics capability
- Basic logs tier for AI verbosity: high-volume AI interaction logs (Copilot prompts, API calls, agent traces) can be ingested into the Auxiliary/Basic tier for retention and ad-hoc search without consuming Analytics tier quota
- Data connectors for AI platforms: native Sentinel connectors for Azure OpenAI, Azure AI Foundry, and Microsoft 365 Copilot provide structured telemetry without custom log parsing

Key AI Security Data Sources for Sentinel

Data Source	Sentinel Connector	Key Log Types	Use Cases
Azure OpenAI	Azure Diagnostics	Request logs, model access, token usage	Anomaly detection, cost attribution, data exfil detection
Azure AI Foundry	Azure Diagnostics	Project activity, model deployments, evaluation results	Configuration change monitoring, unauthorized deployment detection
M365 Copilot	Microsoft 365 (Audit)	CopilotInteraction, plugin usage, sensitivity label changes	Data access anomalies, prompt content analysis, policy compliance
Copilot Studio	Power Platform	Agent activity, conversation transcripts, publishing events	Agent behavioral monitoring, data classification compliance
Microsoft Fabric	Azure Diagnostics / Fabric Monitor	Workspace activity, query execution, data access	Sensitive data access through agents, lineage anomalies
Entra ID	Azure AD (native connector)	Sign-in logs, audit logs, risk events	Agent identity anomalies, privilege escalation, impossible travel
Defender for Cloud	Microsoft Defender for Cloud	Security alerts, recommendations, AI-SPM findings	AI-specific threat alerts, posture degradation

Sentinel Analytics Rules for AI Workloads

Key Sentinel analytics rules organizations should implement for AI security monitoring:

- Spike in Azure OpenAI API calls: detects sudden increases in API call volume suggesting compromised credentials or agent runaway
- Azure OpenAI access from Tor exit nodes or VPNs: high-confidence indicator of credential misuse
- Copilot accessing sensitive labeled content: correlates Copilot interaction logs with sensitivity label events to detect oversharing scenarios
- New MCP server registered in Foundry: alerts on registration of new external MCP servers requiring security review
- Agent service principal signing in from unexpected location: detects potential compromise of agent credentials
- High-volume data retrieval through agent: detects agents retrieving unusually large quantities of data, potential data exfiltration
- Copilot Studio agent published without approval: detects agents bypassing the approval workflow and published directly to production

Microsoft Graph MCP Server for Sentinel

The Microsoft Graph MCP Server (published by the Sentinel team) is a significant capability for AI-powered security operations. It exposes Microsoft Graph data and Sentinel queries through the MCP protocol, enabling:

- Security Copilot can be given MCP tool access to Sentinel, enabling natural language query of security data without requiring KQL knowledge from analysts
- Custom AI agents built in Foundry can be given read access to Sentinel data through the Graph MCP Server for automated threat hunting and reporting
- Integration with third-party AI tools that support MCP for security operations use cases

SECURITY NOTE — Graph MCP Server Access Control

The Microsoft Graph MCP Server should be treated as a privileged tool. Entra applications granted access to the Graph MCP Server should be restricted to Security Reader or Sentinel Reader roles at minimum. Ensure Conditional Access policies apply to the application's authentication, and monitor all Graph API calls made through MCP in Sentinel.

9.2 Security Copilot — AI-Powered Security Operations

Security Copilot Integration Architecture

Security Copilot is now available both as a standalone portal and as an embedded experience within:

- Microsoft Defender XDR: inline AI assistance for incident investigation, alert triage, and guided response
- Microsoft Sentinel: AI-powered KQL query generation, incident summarization, and playbook recommendations
- Microsoft Purview: AI-assisted policy creation, compliance investigation, and insider risk case review
- Microsoft Entra: AI-guided identity investigation and conditional access policy recommendations
- Microsoft Intune: AI-assisted device compliance analysis and policy troubleshooting

Security Copilot Promptbook Library

Security Copilot Promptbooks provide pre-built investigative sequences for common scenarios. AI-specific promptbooks organizations should deploy:

- AI Agent Incident Triage: systematically investigates an alert involving an AI agent, correlating identity events, data access logs, and network activity
- Copilot Oversharing Assessment: analyzes SharePoint access patterns through Copilot for a specified user or group, identifying potential oversharing incidents
- Azure OpenAI Anomaly Investigation: deep investigation of anomalous Azure OpenAI API usage, correlating with identity, network, and data access signals
- Prompt Injection Forensics: analyzes Foundry agent logs to reconstruct a suspected prompt injection attack chain

Security Copilot Custom Agent Platform

Security Copilot now supports custom agents (built on Microsoft Foundry) that extend the Security Copilot experience with organization-specific capabilities:

- Custom threat intelligence agents: agents that query proprietary threat intel feeds and correlate with Sentinel incidents
- Asset inventory agents: agents with access to CMDB or asset management systems to provide richer context during incident investigation
- Compliance verification agents: agents that check specific compliance control states and report findings in Security Copilot investigations

Security Copilot Governance

Security Copilot itself requires governance as an AI system handling sensitive security data:

- Role-based access: Security Copilot Owner, Security Copilot Contributor, and Security Copilot Reader roles control who can use and administer Security Copilot
- Plugin management: control which Security Copilot plugins (including custom organization plugins and third-party plugins) are enabled
- Prompt and response audit: all Security Copilot interactions are logged in Purview Audit for investigation and compliance
- Data residency: Security Copilot processes data in the configured geographic region — verify residency requirements for sensitive investigations

10. Data Security and Governance — Microsoft Purview

10.1 Purview Information Protection for AI

Sensitivity Label Architecture

Microsoft Purview Information Protection sensitivity labels are the foundational data classification mechanism that flows through AI systems. A well-designed label taxonomy is a prerequisite for effective AI data governance:

- Labels should be defined before AI deployment and validated across all document repositories that will be indexed by AI agents
- Auto-labeling policies should be deployed to classify unlabeled content in SharePoint, OneDrive, and Exchange before enabling AI tools that will access that content
- Label inheritance rules should be defined for AI-generated content: when an agent produces a document derived from Confidential source material, the output should inherit at least the Confidential label
- Encryption-based label templates should be carefully evaluated for AI compatibility — encryption with specific user scope can prevent agents from reading protected content even if they have SharePoint access

AI-Aware Labeling Scenarios

Scenario	Purview Control	Configuration Recommendation
Agent reads labeled document	Label-based access in SharePoint / Entra rights management	Ensure AI service principal is in approved access groups for label templates that permit external application access
Agent generates response citing labeled content	Label inheritance for AI outputs	Configure AI app label inheritance policies to apply source document label to AI-generated summaries and citations
User pastes sensitive content into Copilot Chat	Endpoint DLP + Copilot DLP policy	Apply DLP policy detecting sensitive SITs in Copilot Chat input; alert or block based on sensitivity
Agent writes file to SharePoint	Mandatory labeling policy	Require sensitivity label on all items created by agents in governed SharePoint sites; default label for agent-created content
Copilot surfaces unlabeled sensitive content	Auto-labeling + DSPM for AI	Run auto-labeling simulation before Copilot deployment; use DSPM for AI to identify unlabeled sensitive data accessed through AI

10.2 Data Loss Prevention for AI

Copilot and AI-Specific DLP Policies

Purview DLP policies have been extended to cover AI interaction scenarios as of the Ignite 2025 release cycle:

- M365 Copilot DLP policy location: DLP policies can now target M365 Copilot as a specific location, applying policy to Copilot interactions separately from email, SharePoint, or endpoints
- Prompt content inspection: DLP can inspect user prompts to Copilot for sensitive information types (preventing users from pasting sensitive data into Copilot prompts)

- Response content policy: DLP can inspect Copilot responses for sensitive information and apply actions (alert, block, truncate) when sensitive data appears in responses
- Adaptive protection integration: DLP policy restriction levels (block, audit, warn) can be dynamically adjusted based on user risk level from Purview Insider Risk Management

Power Platform DLP as AI Governance

Power Platform DLP policies (separate from Purview DLP) are the primary control for data flows through Copilot Studio agents:

- Every Copilot Studio agent is constrained by the DLP policies of its Power Platform environment — making environment-level DLP design critical
- HTTP connector policies restrict which external URLs agents can call, providing network-layer data flow governance
- Connector endpoint filtering adds finer-grained control within connector tiers (e.g., restrict SharePoint connector to specific tenant's SharePoint domain only)

10.3 DSPM for AI (Data Security Posture Management for AI)

DSPM for AI (generally available as of 2025) is Microsoft's dedicated capability for managing data security risks specific to AI workloads. It represents a significant advancement in AI data governance:

DSPM for AI Capabilities

- Sensitive data discovery in AI knowledge bases: identifies where sensitive data is stored in SharePoint, OneDrive, and other sources indexed by AI tools, prioritized by the AI tools that have access
- AI interaction data analysis: analyzes Copilot and agent interaction data (prompts and responses) for sensitive information exposure incidents
- Oversharing detection: identifies specific documents and users where Copilot is retrieving content that appears inappropriately broad given the user's role
- AI data risk reports: consolidated reports showing the top data risks associated with AI deployment in the tenant, with actionable remediation guidance
- Policy violation detection in AI: detects when AI interactions violate configured Purview policies, correlating with DLP alerts and Communication Compliance detections
- Integration with Microsoft 365 Admin Center: DSPM for AI insights are surfaced in the M365 Admin Center for administrators planning Copilot deployment

DSPM (preview) Capabilities

- **<<insert section on DSPM (preview) here >>>>**

10.4 Insider Risk Management for AI

Purview Insider Risk Management has added specific AI-related risk signals:

- Exfiltration via AI tools: detects patterns where users systematically use Copilot or other AI tools to query, compile, and download organizational data — a pattern consistent with pre-departure data theft
- AI tool access anomalies: unusual patterns of AI tool usage correlated with other risk indicators (recent resignation, performance action, access privilege escalation)
- Sensitive AI prompt patterns: Communication Compliance-based signals detecting prompts that appear designed to extract sensitive organizational information

- Adaptive protection triggering: Insider Risk Management's elevated risk determination automatically increases DLP restriction levels for affected users through Adaptive Protection integration

Insider Risk Policies for AI Environments

Policy Template	AI-Relevant Signals	Recommended For
Data theft by departing users	Bulk Copilot data access + cloud upload + SharePoint download	All organizations deploying M365 Copilot
Data leaks by risky users	Sensitive AI prompt patterns + DLP alert correlation	Regulated industries, defense, financial services
Security policy violations	Copilot attempting access to restricted label content + DLP blocks	All organizations
Cumulative exfiltration	Sustained high-volume AI data retrieval over time	Organizations with high-value IP

10.5 Purview Communication Compliance for AI

Communication Compliance policies can analyze AI interaction content for regulatory and policy compliance:

- Regulatory communication requirements: for financial services, healthcare, and other regulated industries, Communication Compliance policies can review Copilot and agent conversation content for regulatory compliance (e.g., detecting investment advice from a Copilot configured for a regulated context)
- Conflict of interest detection: detect Copilot interactions that suggest potential conflicts of interest in M&A, trading, or client advisory contexts
- Policy violation in AI prompts: detect prompts that violate HR policies, code of conduct, or legal guidelines
- AI misconduct investigation: Communication Compliance provides the investigation workspace for reviewing flagged AI interactions, with evidence collection capabilities aligned to eDiscovery requirements

10.6 Purview eDiscovery and Audit for AI

AI interactions create discoverable data subject to legal hold and eDiscovery requirements:

- M365 Copilot interactions are discoverable: Copilot prompts and responses are stored in Exchange mailboxes (hidden items) and are discoverable through Purview eDiscovery Premium
- Copilot Studio conversation logs: agent conversation transcripts can be preserved under legal hold through Purview eDiscovery
- AI audit log retention: Purview Audit (Premium) provides up to 10-year retention for AI interaction events, critical for regulated industries
- AI-related litigation hold: organizations should include AI interaction data in litigation hold policies to ensure preservation when relevant legal matters arise
- Content search for AI data: Purview Content Search can target Copilot interaction data specifically, enabling focused discovery without processing all mail data

11. AI Governance — Microsoft Agent 365

11.1 Agent 365

Agent 365

Microsoft Agent 365 section here

12. Protocol Security — MCP and Agent-to-Agent (A2A)

12.1 Model Context Protocol (MCP) Security

The Model Context Protocol (MCP), developed by Anthropic and broadly adopted including by Microsoft, provides a standardized protocol for AI agents to discover and call tools (servers) that expose data and capabilities. MCP has rapidly become a de facto standard for agent extensibility, with Microsoft integrating MCP into Foundry, Copilot Studio, and Windows Copilot Runtime. This broad adoption makes MCP security a priority concern.

MCP Threat Model

Threat	Description	Mitigation
Malicious MCP Server	An attacker operates an MCP server that returns tool results containing prompt injection payloads	Allowlist MCP servers; sandbox tool result processing; implement Prompt Shield on tool outputs
Rug Pull Attack	MCP server changes its tool definitions after authorization to expand capabilities maliciously	Version-lock MCP server manifests; re-validate on tool definition changes; use pinned server registrations
Tool Poisoning	MCP server tool descriptions contain hidden instructions visible to the LLM but not the user	Inspect tool descriptions through automated analysis; require human review of third-party MCP tool manifests
MCP SSRF	Agent instructed to call MCP server pointing to internal resources the agent can reach but users cannot	Network isolation for MCP servers; validate server URLs against allowlists; use Entra Internet Access for agent traffic
Credential Exposure in MCP	MCP server credentials (API keys) managed insecurely in the agent definition	Use Azure Key Vault for MCP server credentials; never embed secrets in agent definitions
MCP Protocol Downgrade	Attacker forces use of older, less secure MCP protocol version	Enforce minimum MCP protocol version in server registrations; monitor for version negotiation anomalies

Microsoft MCP Server Security Controls

Microsoft has published first-party MCP servers for core services (Microsoft 365, Teams, SharePoint, Sentinel, Graph) that are designed with enterprise security in mind:

- Entra ID authentication: Microsoft MCP servers use Entra ID OAuth flows for authentication, ensuring all calls are traced to an authenticated identity
- Graph-permission-bounded: Microsoft Graph MCP servers operate under the delegated or application permissions granted to the registered Entra application — they cannot exceed the Graph API permission grant
- Audit logging: all MCP tool calls to Microsoft servers are logged in Entra sign-in logs and Microsoft 365 Audit Logs
- Rate limiting and throttling: Microsoft MCP servers implement Graph API throttling limits, providing some protection against agent runaway scenarios

MCP Server Governance for Enterprise Deployments

- Maintain an organizational MCP server registry: approved MCP servers with version, security review status, and authorized usage scope
- Implement a review process for new MCP server requests analogous to third-party software review
- Use Azure API Management as a proxy layer for all outbound MCP server calls from Foundry agents, enabling centralized logging, rate limiting, and policy enforcement
- Monitor MCP server call patterns in Sentinel for anomalies: unusually high call volumes, calls to previously unused servers, or calls to servers from unexpected agent identities
- Apply Entra Conditional Access to MCP server authentication where Entra-based auth is used

12.2 Agent-to-Agent (A2A) Protocol Security

The Agent-to-Agent (A2A) protocol, developed by Google with broad industry support including Microsoft, provides a standardized mechanism for AI agents to delegate tasks to other agents, discover agent capabilities, and exchange context. Microsoft has announced A2A support in Foundry and Copilot Studio, with progressive rollout through 2026.

A2A Trust Model

The A2A protocol defines an Agent Card — a JSON document describing an agent's identity, capabilities, authentication requirements, and endpoints. The trust model for A2A in enterprise environments must address:

- Agent Card authenticity: how does a calling agent verify that an Agent Card genuinely represents the claimed agent and has not been tampered with? Microsoft's implementation uses Entra-issued tokens with agent claims.
- Cross-tenant trust: when agents in different organizations need to interact via A2A, how is cross-tenant trust established? Entra B2B and Entra Verified ID are the mechanisms under development.
- Task delegation authorization: agent A can call agent B, but can A actually authorize B to perform the requested action on A's user's behalf? OAuth 2.0 delegation and token-in-token patterns (RFC 8693) are the standard approach.
- Audit trail continuity: as a task passes through a chain of agents (A → B → C), the full chain must be preserved in audit logs for forensic traceability

A2A Security Controls in Microsoft Foundry

- Entra-based A2A authentication: agents registered in Foundry receive Entra workload identities; A2A calls between Foundry agents use Entra token-based authentication
- A2A task authorization policies: Foundry supports configurable policies defining which agents can delegate to which other agents, preventing unauthorized agent-to-agent communication
- A2A audit log: all A2A interactions are logged with source agent identity, target agent identity, task description, and outcome
- Sensitive action confirmation: configurable policies requiring human confirmation before an agent acting on behalf of another agent performs sensitive actions (e.g., send email, create record)

A2A Security Controls in Copilot Studio

Copilot Studio's A2A capabilities (in preview as of early 2026) include:

- Orchestrator-worker pattern: a designated orchestrator agent manages task delegation to worker agents; the orchestrator's identity is tracked throughout
- Worker agent capability declaration: worker agents declare their capabilities in their Agent Card; orchestrators can only invoke declared capabilities
- Power Platform DLP for A2A: DLP policies apply to data exchanged between agents in A2A patterns within the Power Platform boundary

> **NOTE — A2A Maturity**
> A2A protocol support across the Microsoft platform is maturing through 2026. Security controls described here reflect announced capabilities and expected GA timelines. Organizations implementing A2A patterns should follow Microsoft's AI platform release notes and participate in preview programs to validate security controls before production deployment.

13. API Management and Security Considerations

13.1 Azure API Management as the AI Security Gateway

Azure API Management (APIM) serves as the centralized security gateway for AI APIs across all Microsoft AI platforms. Positioning APIM in front of Azure OpenAI, Foundry endpoints, and MCP servers provides a consistent control point for policy enforcement, monitoring, and governance.

13.2 Key APIM Security Capabilities for AI

AI Gateway Policies

Azure APIM's built-in AI gateway policies provide purpose-built controls for LLM APIs:

- Token rate limiting: limit the number of tokens (not just requests) that a consumer can send in a time window — critical for controlling costs and preventing abuse
- Token usage metrics: emit per-consumer, per-model token usage to Azure Monitor for cost allocation, anomaly detection, and capacity planning

- LLM semantic caching: cache LLM responses for semantically similar prompts, reducing latency and cost while also reducing repeated exposure of cached sensitive responses
- Prompt content policies: apply content inspection policies to prompts before they reach the model, integrating with Azure AI Content Safety
- Backend load balancing across OpenAI deployments: distribute load across multiple Azure OpenAI deployments with priority and weight, supporting failover and regional distribution

Authentication and Authorization at the API Gateway

- OAuth 2.0 JWT validation: validate Entra ID tokens at the APIM layer before forwarding requests to backend AI services, ensuring only authenticated identities can reach AI endpoints
- Subscription key management: for scenarios using subscription-key auth, APIM manages key lifecycle and provides per-key analytics
- Client certificate authentication: for high-assurance scenarios, require TLS client certificate authentication at the APIM gateway
- API product and subscription model: organize AI APIs into products with associated usage policies, enabling per-consumer rate limits and audit trails

Threat Protection at the API Layer

- OWASP API security policy: apply OWASP API Security Top 10 mitigations through APIM policies including injection prevention, authentication enforcement, and rate limiting
- Defender for APIs integration: Defender for APIs (now GA) integrates with APIM to provide automated discovery of all APIs in the APIM gateway, behavioral analytics detecting unusual API call patterns, and vulnerability assessment of API definitions
- JWT claim validation: validate specific JWT claims (e.g., required scopes, allowed audiences, tenant ID) to prevent cross-tenant token reuse
- IP filtering and geo-blocking: restrict API access to approved IP ranges and geographies at the APIM layer

API Security for External AI Integrations

When AI agents call external APIs (third-party services, partner APIs, custom backends):

- Store all external API credentials in Azure Key Vault and reference them in APIM backend policies — never hard-code credentials in agent definitions
- Use APIM as the egress proxy for all external API calls from Foundry agents, providing a single point of audit and control
- Apply rate limiting on external API calls to prevent agent runaway scenarios from generating excessive third-party API costs or triggering abuse detection
- Validate API response schemas before returning to agents to prevent unexpected data structures from causing agent misbehavior

13.3 API Security for Fabric Data Agents

Fabric data agents expose natural language query interfaces that ultimately translate to API calls against Fabric. Security considerations:

- Fabric REST API authentication: use Entra service principals or managed identities for programmatic Fabric API access — never use personal access tokens in production agent code
- Semantic model REST API: when agents query Fabric semantic models through the REST API, Entra-based token authentication is required and row-level security is enforced
- API throttling limits: Fabric API calls are subject to Fabric capacity limits; agent implementations should include retry logic with exponential backoff to handle throttling gracefully

14. DevSecOps — GitHub, CI/CD, and AI Landing Zones

14.1 Secure AI Development with GitHub

GitHub Advanced Security for AI Projects

GitHub Advanced Security (GHAS) provides the foundational security scanning layer for AI application development:

- Secret scanning with AI validity: GHAS secret scanning now includes patterns for Azure OpenAI API keys, Foundry project credentials, and Copilot connector credentials — detected secrets are immediately flagged and optionally blocked from merging
- Push protection: prevents secrets from being committed to repositories in the first place, the most effective control for credential exposure
- Code scanning (CodeQL): static analysis of agent code including Python (for Foundry SDK code), TypeScript/JavaScript (for Copilot Studio custom code), and Power Fx — identifies security vulnerabilities including injection vulnerabilities, insecure credential handling, and data validation gaps
- Dependency review: scans pull requests for vulnerable dependencies introduced in AI projects (e.g., outdated Python AI libraries with known CVEs)
- Copilot Autofix: GitHub Copilot in GHAS automatically suggests fixes for code scanning alerts, reducing developer friction in addressing security findings in AI project code

GitHub Actions Security for AI CI/CD

GitHub Actions is the primary CI/CD mechanism for AI application deployments. Security hardening:

- Workload Identity Federation: configure Foundry and Azure deployments to use Workload Identity Federation with Entra, eliminating stored Azure credentials in GitHub Secrets
- OIDC token configuration: restrict OIDC token issuance to specific branches (main, release/*) and workflow files to prevent token misuse from feature branches
- Environment protection rules: configure GitHub Environments for production Foundry deployments with required reviewers, deployment approval, and branch restrictions
- Pinned action versions: use SHA-pinned GitHub Actions versions (not mutable tags) to prevent supply chain attacks through malicious action updates
- Minimal permissions in workflows: configure GITHUB_TOKEN permissions at the workflow level with only the scopes needed — AI deployment workflows rarely need write access to contents
- Repository secrets lifecycle: rotate all repository secrets on a defined schedule and remove unused secrets; Entra Workload Identity Federation eliminates most secrets entirely

14.2 AI-Specific CI/CD Security Controls

AI Model and Prompt Security in Pipelines

AI applications have unique CI/CD security requirements beyond traditional software:

- System prompt version control: system prompts that define agent behavior should be stored in version control alongside code, with the same change control and review processes as code

- Prompt security scanning: integrate automated scanning of system prompts in CI pipelines to detect instruction injection risks, overly broad permissions declarations, or sensitive information included in prompts
- Model evaluation gates: automated evaluation jobs in CI pipelines that run red team test sets against agent builds, failing the pipeline if harmful output rates exceed configured thresholds
- Content safety testing: run Azure AI Content Safety evaluation against model outputs as a required CI gate before production deployment
- Sensitive data in test inputs: ensure CI pipeline test data does not contain real production data — use synthetic data generation for AI evaluation datasets

Infrastructure as Code Security for AI

- Azure Verified Modules for AI: use Microsoft-maintained Azure Verified Modules (Bicep and Terraform) for deploying Foundry hubs, Azure OpenAI resources, and APIM — these modules encode security best practices by default
- Checkov and tfsec scanning: run IaC security scanners in CI pipelines to catch misconfigurations before deployment (e.g., public network access enabled, CMK not configured, diagnostic settings missing)
- Azure Policy compliance gates: use Azure Policy compliance API in CD pipelines to verify that deployed AI resources comply with all assigned policies before marking a deployment successful
- Drift detection: configure Sentinel analytics rules or Defender for Cloud to alert when AI resource configurations drift from the IaC-defined baseline

14.3 Threat Modeling for AI Applications

Threat modeling should be a required phase of the AI application development lifecycle, not an afterthought. A practical threat modeling approach for AI applications:

AI Threat Modeling Process

- Step 1 — Data Flow Diagramming: map all data flows involving the AI agent: user input paths, knowledge base retrieval paths, tool call paths, external API calls, and output paths. Include all trust boundaries.
- Step 2 — STRIDE Analysis: apply STRIDE analysis to each component and data flow, with specific attention to Spoofing (agent identity), Tampering (prompt injection, data poisoning), Information Disclosure (sensitive data in responses, system prompt extraction), and Elevation of Privilege (tool permission abuse)
- Step 3 — MITRE ATLAS Mapping: map identified threats to ATLAS techniques for AI-specific threat categorization and to ensure coverage of AI-unique attack patterns
- Step 4 — Control Identification: for each threat, identify the Microsoft Security platform control that mitigates it (e.g., Prompt Shield for prompt injection, Content Safety for harmful outputs, Entra RBAC for privilege escalation)
- Step 5 — Residual Risk Assessment: document threats where available controls provide incomplete mitigation and design compensating controls or accept residual risk with documented justification
- Step 6 — Red Team Testing: validate threat model assumptions through red team exercises targeting the specific threats identified, using adversarial prompt libraries and automated evaluation frameworks

Microsoft Threat Modeling Tools for AI

- Microsoft Threat Modeling Tool: available as a free download, with AI-specific templates being developed for the Foundry and Azure AI ecosystem
- PyRIT (Python Risk Identification Toolkit for Generative AI): Microsoft's open-source framework for red-teaming AI systems, integrating with Azure AI evaluations in Foundry
- Azure AI Evaluation SDK: part of Foundry, provides automated safety evaluation including content safety, groundedness, and jailbreak resistance testing
- GitHub Copilot for Security: code review assistance that can identify security issues in AI application code during development

14.4 Intune — Securing Developer and User Devices

Microsoft Intune is the device management layer that ensures developer workstations and user devices meet security requirements for AI tool access:

- Compliance policies for AI tool access: Conditional Access policies requiring Intune-compliant devices for access to Foundry, Copilot Studio, and M365 Copilot ensure only managed devices access AI development environments
- Application protection policies (APP) for mobile: for M365 Copilot mobile access, Intune APP policies enforce data protection requirements (prevent copy/paste to unmanaged apps, require PIN)
- Endpoint DLP enforcement: Purview Endpoint DLP policies enforced through the Intune device management channel prevent sensitive AI-generated content from being copied to unmanaged storage
- Dev Box for AI development: Microsoft Dev Box (managed developer workstations) provides Intune-managed, pre-configured environments for AI engineers, ensuring consistent security posture without friction
- Privileged Access Workstations (PAW): for AI platform administrators, Intune-managed PAW configurations with restricted software installation, enhanced monitoring, and phishing-resistant authentication requirements

15. Cross-Platform Security Comparison

15.1 Security Capability Comparison Across AI Platforms

The following comparison illustrates the security capabilities and controls available across the primary Microsoft AI platforms. Where capabilities overlap, they are noted; where gaps exist, they are highlighted as areas requiring compensating controls.

Security Domain	M365 Copilot	Copilot Studio / Power Platform	Microsoft Foundry	Microsoft Fabric
Identity	Entra ID (user) MSA not supported	Entra ID (user + SPN) Custom IdP option	Entra ID (user + managed identity + SPN)	Entra ID (user + SPN)
Network Isolation	Microsoft-managed (SaaS) No customer VNet option	Limited — Entra Internet Access for egress control	Full private endpoint + managed VNet support	Private Link + managed private endpoints
Data Classification	Sensitivity label enforcement (read) Label inheritance (partial)	Label-aware retrieval from SharePoint No native label creation	No native Purview label enforcement Custom content filtering	Purview label scanning and propagation RLS/CLS/OLS support
DLP Integration	Purview DLP (Copilot location) Endpoint DLP	Power Platform DLP (connectors) Purview DLP (limited)	Custom content safety No native Purview DLP	Purview DLP on downstream M365 surfaces
Audit Logging	Purview Audit + M365 Unified Audit Log	Power Platform Admin Center Purview Audit (limited)	Azure Monitor + Log Analytics Foundry Audit	Fabric Monitor + Purview Audit
Threat Detection	Defender XDR anomaly detection DSPM for AI	Defender for Cloud Apps Power Platform analytics	Defender for Cloud AI-SPM Prompt Shield	Defender for Cloud Fabric capacity monitoring
Content Safety	Built-in (Microsoft-managed)	Built-in Azure AI Content Safety	Configurable Azure AI Content Safety Custom filters	Query safety via semantic model governance
Compliance	Purview Compliance Manager Comm Compliance eDiscovery	Limited — no native eDiscovery Communication Compliance (partial)	Azure compliance controls Purview integration (limited)	Purview compliance scanning Data lineage for compliance

15.2 Overlapping Controls — Governance Considerations

Several security capabilities span multiple platforms, which creates both strength (defense in depth) and governance complexity (multiple policy systems to manage):

- Sensitivity labels span all platforms but with different enforcement: labels are enforced natively in M365 Copilot and Fabric, require custom implementation in Foundry, and have partial support in Copilot Studio. Organizations must understand which platform enforces which label controls.
- Entra ID is the identity control plane across all platforms, but the depth of integration varies. Managed identities (Foundry, Fabric) provide stronger security than user-delegated access (Copilot Studio custom auth), but not all scenarios support managed identities.
- Audit logging goes to different stores across platforms: Purview Audit (M365, Copilot Studio), Azure Monitor / Log Analytics (Foundry, Fabric), and Power Platform Admin Center (Copilot Studio operational). Sentinel with appropriate connectors is the unification layer, but connector completeness varies.
- Content safety is enforced at different layers: Microsoft-managed in M365 Copilot, configurable in Foundry and Copilot Studio, and absent in custom Fabric data agent implementations (requiring custom application-layer controls).

15.3 Common Use Case Security Patterns

Finance — Internal Financial Reporting Agent

A financial reporting agent that queries Fabric data warehouses and generates reports:

- Foundry or Copilot Studio for agent implementation (Foundry preferred for complex data access patterns)
- Fabric with RLS/CLS to restrict data access to only the financial data the agent's service principal is authorized for
- Purview sensitivity labels on all financial data in Fabric; label inheritance to generated reports
- Purview Insider Risk Management monitoring for unusual data access patterns through the agent
- Defender for Cloud AI-SPM monitoring the Foundry deployment for security posture
- Communication Compliance for agent-to-user financial communications in regulated contexts

HR — People Analytics Agent

An HR analytics agent providing managers with workforce insights:

- M365 Copilot with Microsoft Graph data access (respecting existing SharePoint and Teams permissions)
- SharePoint Advanced Management to restrict HR data sites to appropriate groups before Copilot deployment
- DSPM for AI to monitor for oversharing of sensitive HR data through Copilot
- Purview DLP policies blocking Copilot responses containing PII patterns to users without HR permissions
- Entra ID Governance access reviews for HR data site permissions on a quarterly basis
- Insider Risk Management monitoring for unusual HR data access patterns

Customer Service — External-Facing Support Agent

A customer-facing support agent deployed on a company website:

- Copilot Studio with web channel deployment and custom (Entra B2C or third-party) authentication
- Power Platform DLP to restrict agent to approved knowledge base connectors only
- Azure AI Content Safety at Strict threshold for all inputs and outputs
- Prompt Shield in document mode for all retrieved knowledge base content
- Azure API Management in front of the Copilot Studio DirectLine endpoint for rate limiting and DDoS protection

- Defender for Cloud Apps monitoring for unusual call volumes indicating abuse
- APIM with Bot Framework authentication for bot-specific threat patterns

16. Limitations, Gaps, and Roadmap Considerations

As the Microsoft AI security platform continues to mature rapidly, it is important to clearly document current limitations alongside planned capabilities. Organizations should factor these gaps into their security architectures and implement compensating controls where needed.

Gap / Limitation	Affected Platforms	Current Compensating Control	Roadmap Status (2026)
Entra Agent ID not fully GA	All platforms	Use service principals with least-privilege; monitor for Entra Agent ID GA announcement	In preview; GA expected H1 2026
A2A protocol security controls maturing	Foundry, Copilot Studio	Limit A2A to preview environments; implement custom authentication validation	Security controls GA expected H2 2026
Purview DLP for Copilot Studio outputs limited	Copilot Studio	Power Platform DLP for connector control; Communication Compliance for content review	Enhanced Purview integration on roadmap
Sensitivity label inheritance for AI-generated content inconsistent	M365 Copilot, Copilot Studio	Mandatory labeling policies; Purview auto-labeling on output locations	Full label inheritance GA expected 2026
Foundry lacks native Purview DLP enforcement	Microsoft Foundry	Custom content safety policies; APIM response inspection; Defender for Cloud alerts	Purview-Foundry integration on roadmap
Sentinel connector completeness for AI platforms varies	All platforms	Custom diagnostic settings to Log Analytics; custom data connectors	Additional GA connectors expected throughout 2026
MCP server governance tools immature	Foundry, Copilot Studio, Windows	Manual MCP server registry; APIM proxy for MCP calls	MCP governance tooling in development
Fabric data agent audit log granularity	Microsoft Fabric	Fabric Monitor + KQL database audit logs as supplement	Enhanced audit capabilities on roadmap
AI threat detection coverage in Sentinel not complete	All platforms	Custom KQL analytics rules; manual threat hunting for AI-specific patterns	Additional built-in AI threat detections planned
Cross-tenant A2A trust model not established	Foundry, Copilot Studio	Avoid cross-tenant A2A until framework matures; use API-based integration instead	Entra Verified ID integration for A2A planned

17. Implementation Roadmap

17.1 Phased Security Implementation

The following phased approach provides a structured path to implementing comprehensive AI security controls. Organizations should adapt the phases to their current security maturity, existing Microsoft licensing, and AI deployment timeline.

Phase 1 — Foundation (Months 1-3)

Establish the foundational identity, governance, and visibility controls before or concurrent with initial AI deployment:

- Enable Purview Audit (Premium) for all relevant workloads to ensure AI interaction data is captured from day one
- Connect Azure Monitor from Foundry, Azure OpenAI, and Fabric to a central Log Analytics workspace feeding Sentinel
- Run SharePoint Advanced Management DAG reports and remediate high-risk oversharing before enabling M365 Copilot
- Configure Conditional Access policies for all AI tool access: require MFA and compliant devices as baseline
- Classify all Power Platform connectors used by existing Copilot Studio agents under DLP policies
- Enable Defender for Cloud with AI-SPM plan on all Azure subscriptions hosting AI workloads
- Establish an MCP server governance registry and review process
- Configure GitHub Advanced Security on all AI project repositories with secret scanning push protection enabled

Phase 2 — Enhanced Controls (Months 3-6)

- Deploy DSPM for AI and review initial data risk findings; remediate top-risk oversharing and unlabeled sensitive data scenarios
- Implement sensitivity auto-labeling for SharePoint content accessed by AI agents
- Deploy Purview DLP policies targeting M365 Copilot interactions for sensitive information type patterns
- Implement Insider Risk Management policies for AI data exfiltration detection
- Configure Azure AI Content Safety (Prompt Shield + content filters) for all Foundry deployments
- Deploy Azure API Management in front of Azure OpenAI endpoints with token rate limiting and usage tracking
- Implement Foundry private endpoint configuration for production workloads
- Enable Entra ID Governance access reviews for AI tool access, quarterly cadence

Phase 3 — Advanced Capabilities (Months 6-12)

- Implement Security Copilot with AI-specific promptbooks for incident investigation
- Develop custom Sentinel analytics rules for AI-specific threat scenarios based on Phase 1-2 observation data
- Implement threat modeling process for all new AI agent projects as a required SDLC gate

- Deploy PyRIT-based red team evaluation in CI/CD pipelines for production agent deployments
- Configure Communication Compliance policies for Copilot and agent interactions in regulated contexts
- Implement Fabric data agent security controls: OneLake Data Access Roles, private links, Purview scanning
- Deploy Entra Internet Access with AI-specific FQDN filtering for agent network egress control
- Establish A2A security framework as preview capabilities mature toward GA

Phase 4 — Continuous Improvement (Ongoing)

- Monthly review of DSPM for AI findings with remediation SLAs
- Quarterly red team exercises against production AI agents
- Annual threat model refresh for all production AI applications
- Continuous monitoring of Microsoft AI security release notes and roadmap updates
- Bi-annual access reviews for all AI platform administrative roles
- Ongoing evaluation of Entra Agent ID and A2A protocol GA features as they become available

18. Summary and Conclusion

Securing AI agents and applications across the Microsoft platform requires a fundamentally different approach from traditional application security. The attack surface is broader, the trust model is more complex, and the data access patterns are more expansive. However, the Microsoft Security platform provides a comprehensive, deeply integrated set of controls that — when correctly configured and combined — deliver genuine defense in depth for enterprise AI deployments.

The key principles that should guide AI security architecture across the Microsoft ecosystem:

- Identity is the perimeter: in an AI-native world, every data access by an agent should be traceable to a specific identity, authorized through Entra, and auditable through Purview. Managed identities and workload identity federation eliminate the credential hygiene failures that have historically compromised AI systems.
- Least privilege is non-negotiable: the scope of permissions granted to AI agents directly determines the blast radius of any compromise or manipulation. Invest in scoping tool permissions, SharePoint access, Graph API scopes, and Azure RBAC to the minimum required for each agent's declared function.
- Data governance enables AI governance: sensitivity labels, DLP policies, and Purview data governance controls that were deployed for human data access apply equally to AI agents. Organizations that have invested in Purview data governance are significantly better positioned for secure AI deployment.
- Visibility must be comprehensive: AI interactions produce a new class of security telemetry that must be captured in Sentinel from day one. Attempting to investigate AI security incidents without adequate logging is futile — logging configuration is a prerequisite, not an afterthought.
- Security posture is continuous: AI agent configurations drift, permissions expand, and new threats emerge. Defender for Cloud AI-SPM, DSPM for AI, and automated policy compliance checks provide the continuous posture monitoring that point-in-time assessments cannot.
- Developer security is as important as runtime security: the security of AI agents is determined significantly by how they are built. GitHub Advanced Security, secure CI/CD pipeline practices, threat modeling, and red team evaluation in pipelines extend security left into the development lifecycle.

The Microsoft Security platform is evolving rapidly to address the AI security challenge, with Ignite 2025 marking a significant maturation point with AI-SPM, DSPM for AI, Sentinel Data Lake, and Entra Agent ID all advancing substantially. Organizations that build their AI security architecture on these platform capabilities — rather than attempting to build custom security controls — will benefit from Microsoft's ongoing investment and integration depth.

The roadmap into 2026 promises further maturation: Entra Agent ID general availability, A2A protocol security controls, deeper Purview integration across Foundry and Copilot Studio, and enhanced Sentinel analytics for AI workloads. Security architects should plan architectures that can evolve with these capabilities while implementing robust compensating controls for current gaps.

AI agents are not merely a new application category — they represent a new computing paradigm with new security requirements. The organizations that treat AI security as a first-class architecture concern, applying the full depth of the Microsoft Security platform from identity through data governance, threat protection, and security operations, will be positioned to realize the full value of AI while managing the genuine risks it introduces.

Version 1.0 | February 2026 | Based on Microsoft Ignite 2025 announcements and Microsoft platform documentation